HeyFY

Project - 3

RTR 방식 + 세션 기반 인증/인가 설계

상황

RTR(Refresh Token Rotation) 기반의 인증/인가 방식을 이미 구현한 상태
이후 다음과 같은 보안 요구사항 추가

- 금융 관련 API에 한해 **30분 단위로 PIN(2차 비밀번호) 인증 요구**
- **1주일 단위 재로그인(ID/PW) 요구**
- 개발 기간이 촉박하여 **인증/인가 전체 구조를 새로 설계·구현하기는 어려운 상황**

기존 RTR 구조를 유지하면서도, 민감 API 보호를 위한 추가 인증 레이어가 필요

해결방안

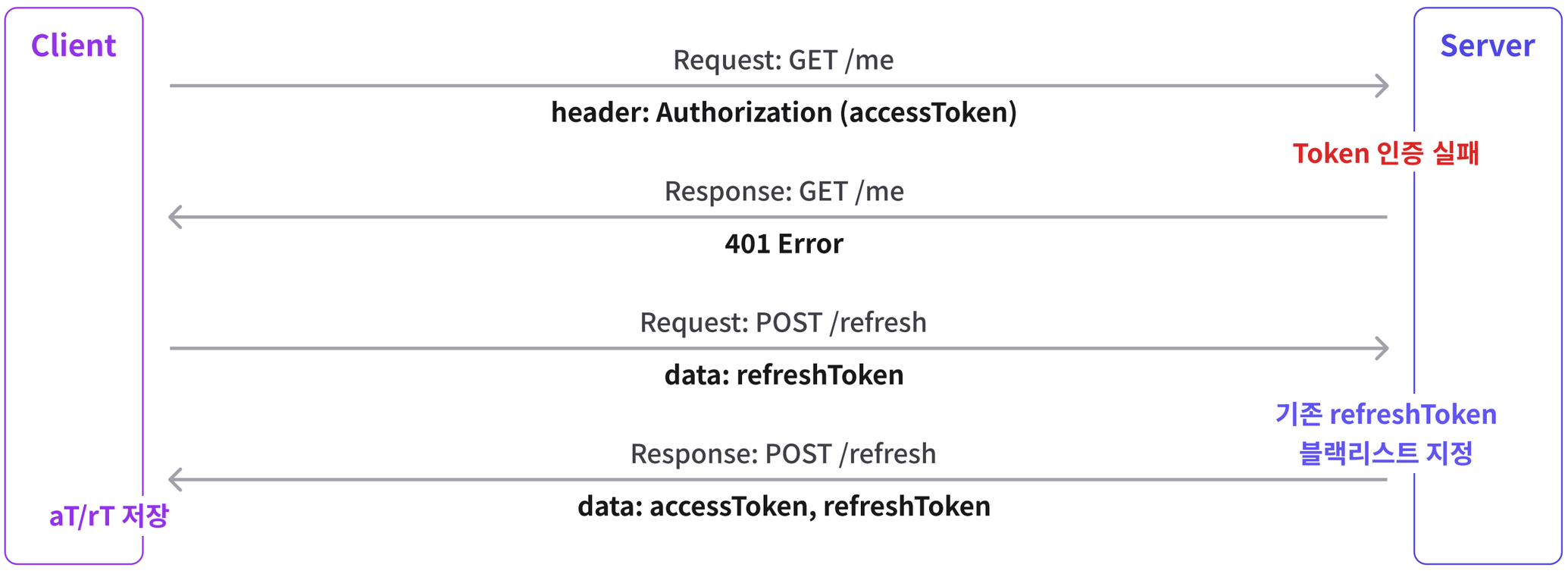
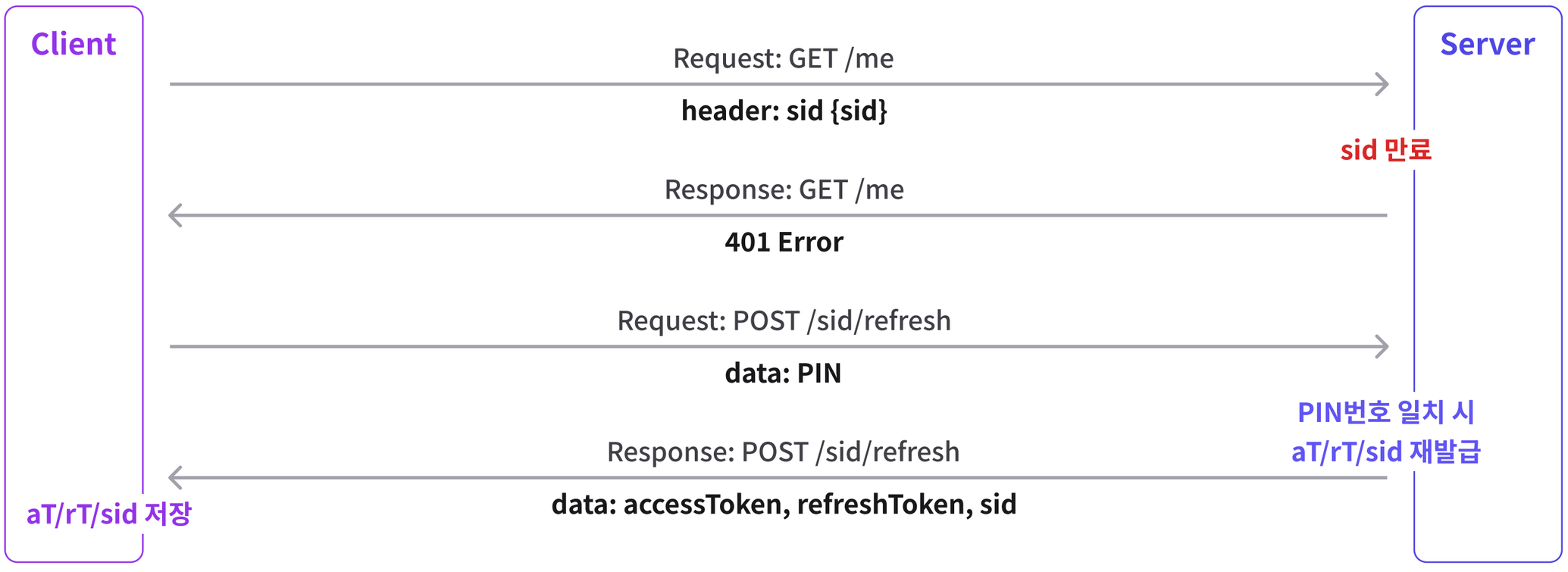
기존 RTR 구조 위에 세션을 추가해 **짧은 보안 세션 + 긴 로그인 세션**을 분리하는 방식으로 문제를 해결

Access Token (AT)
- 짧은 수명
- 일반 API 인증용

Refresh Token (RT)
- 비교적 긴 수명 (약 1주)
- AT 재발급 용도
- RTR 방식 적용

SID (Session ID)
- **PIN 인증 성공 시에만 발급**
- 민감 API 접근을 위한 추가 인증 수단
- 만료 시간 30분(Redis TTL)

토큰 재발급 (AccessToken & RefreshToken)



세션 갱신 (SessionID & AccessToken & RefreshToken)